

We Are Terrible at Online Identity Management (or: Using Emails as An Identifier Was a Bad Move)

Cite as: Martin Paul Eve, "We Are Terrible at Online Identity Management (or: Using Emails as An Identifier Was a Bad Move)", *eve.gd: Martin Paul Eve*, July 26, 2023, <https://doi.org/10.59348/p3qjk-zak81>.



As noted previously, I am [vacating my martineve.com domain](#). To do so has been a painful process that involves changing every account that uses martin@martineve.com to a new email address.

This is painful because it turned out to be about 350 accounts. Different sites categorise the email differently. Sometimes it is under “profile”, other times “settings”, or on occasion “account”. Then there are the sites that require you to *call them* to make this change. Finally, the worst of all: sites that say you *cannot* change the email address, because they have to keep records or something. I have pointed out to them that this is a massive security risk, but have been met with “meh”.

Single sign-on/oAuth was meant to fix this. Use your Google account ([or ORCID!](#)) to sign in instead. However, in my experience this weekend, lots of sites implement such authentication flows very badly. For instance, a well-known cloud provider allows login via Google. Yet, if you then change the email address on the Google account, you are locked out. That’s right: instead of using the account ID that Google provides (allowing for a change of email), they locked the login to the *email* sent by Google on the authorisation flow.

These OAuth providers are meant to act as intermediaries between a mutable email address and the immutable identity of the account holder. Just as DOIs sit between an end-user and an article – and can be updated if the article's URL changes – the OAuth flows were meant to add a neutral account layer, not tied to the identifier of an email, in the middle. Of course, they themselves are still subject to problems. If you lose access to such a centralised login provider, you lose access to all your accounts, everywhere. For this reason, many sites also allow you to do a password reset using the email address they have on file. But this means that, once more, every site everywhere is storing an email address that must be changed if you ever lose it.

It would be nice to envisage some kind of API for email and password changes, which could then be used by a password manager to change everything *en masse*. There are, of course, infosec implications for such an API, and any bug would be catastrophic from a security perspective. But at the moment, forgetting to reset your email somewhere is also really bad from a security perspective, leading to data leaks and the potential for identity theft ([a horrible term](#)). Mind you, this whole experience has shown me that if you are not using a password manager in this day and age, you would have no chance of successfully changing your email everywhere. Even enumerating the accounts that you have would be nigh-on impossible.

I think that, overall, the web would be better if every site everywhere stopped asking for you to have an account for transient, one-off transactions. When I found myself changing my email address on the site for a German taxi company that I had used over half a decade ago, once, the patent ridiculousness of it all became clear. The problem is that the web has developed to thrive on the monetisation of user data through advertising. Without tying end-users to an account, it becomes much harder to track them and, as a result, harder to profile them through advertising. Retail outlets online also want to keep customer details for marketing purposes to try to secure future sales. These factors all encourage sites to collect emails, which are then used as identifiers, even though they are a poor mutable proxy for identity.

Of course, we do need to track users in some environments. Access to an email address is usually well secured and so it looks like a viable identifier. However, the lock-in that is engendered by this is substantial. Just think: if you wanted to change your email address, how much of a pain would it be? How much would someone have to pay you to do so? Hint: it's quite a lot.

It's also worth considering what this does for generic email providers like Gmail. It's virtually impossible to leave them once you have an account there, because so many other accounts are tied to their service. As the song goes: you can check out any time you like, but you can never leave. Having your own domain, again, intermediates this problem. If you control your own MX records, you can repoint the MX to a different provider and the address can remain the same. However, most people are not tech savvy enough to do this and just use standard Gmail (for example) addresses. Let's hope that Google never shuts Gmail!

Overall, as I said, it has been painful switching domains. I think I am just about there now, but it has prompted me to reflect on how bad we are at online identity management, using emails as identifiers in inappropriate ways.